11.1.3 Pattern 3: Per-service proxies

Not all ACME services were behind the API gateway or ready to be integrated into the service mesh. Some teams operated their APIs on infrastructure that didn't yet support the mesh. To address these gaps, Bob suggested deploying per-service proxies. Each critical service would be placed behind a lightweight proxy such as Envoy (https://www.envoyproxy.io). The proxy would serve as a policy enforcement point (PEP): terminating TLS, validating service identity, and requesting Cedar for an authorization decision before forwarding the request to the API.

Finance was among the first teams to adopt this model. Their API provided endpoints for retrieving cost-center data. Carol uses the Manager Dashboard to monitor her department's budget alongside HR data and customer assignments. When the dashboard requests data from the Finance API, the request first passes through the Finance service proxy, as shown in figure 11.3.

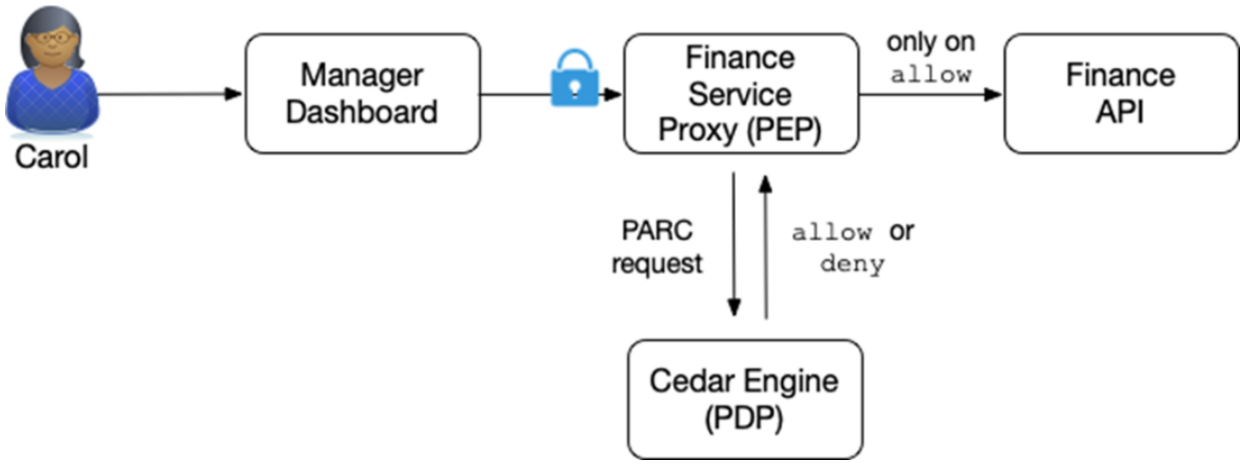


Figure 11.3 Per-service proxy enforcement. Carol's Manager Dashboard requests cost-center data from the Finance API. The request first passes through a proxy that verifies service identity and consults Cedar. Managers can view their own cost centers, but requests for other departments are denied.

ACME wanted managers like Carol to view data only for their own cost centers, not for those in other departments. Alice's team described this requirement as a Cedar policy: